

QED-Lite: 라이브러리 버전 핑거프린팅 기반 경량 양자 취약 ELF 바이너리 탐지

김하경*, 이승원**, 방지원*, 김의재*, 강희주*, 김민서*, 서화정†

한성대학교 (학부생, 대학원생**, 교수†)

QED-Lite: Lightweight Detection of Quantum-Vulnerable ELF Binaries via Cryptographic Library Version Fingerprinting

Ha-Gyeong Kim*, Seung-Won Lee**, Ji-Won Bang*, Ui-Jae Kim*, Hui-Ju Kang*, Min-Seo Kim*, Hwa-Jeong Seo†

Hansung University (Undergraduate student, Graduate student**, Professor†)

요약

양자 컴퓨팅의 발전은 공개키 암호 체계에 심각한 위협을 제기하고 있으며, 각 조직은 시스템 내 양자 취약(QV) 실행파일을 식별하고 PQC로 전환해야 하는 과제에 직면해 있다. 선행 연구인 QED는 angr 기반 정적 콜그래프 분석으로 높은 탐지 정밀도를 달성하지만, 데이터셋당 수 분에서 십여 분의 처리 시간과 최대 5GB에 달하는 RAM 소모로 인해 대규모 환경에서의 전수 스크리닝에 현실적인 한계가 있다. 본 논문에서는 탐지 정밀도에 비해 높은 연산 오버헤드를 유발하는 분석 단계를 경량화하고 암호 라이브러리 버전 기반 PQC 지원 판정으로 대체한 경량 근사 도구 QED-Lite를 제안한다. 실험 결과, Network 데이터셋 기준 TPR 100%를 유지하면서 QED 대비 최대 855배 빠른 실행 시간(0.84초)과 228배 적은 메모리 사용량(22.9MB)을 달성하였다.

I. 서론

"지금 수집, 나중에 해독(Harvest Now, Decrypt Later, HNDL)" 공격 시나리오는 PQC로의 전환 시급성을 극대화하고 있으며, NIST는 ML-KEM 등 PQC 표준을 공식 채택하며 표준화 작업을 완료하였다 [1]. 성공적인 PQC 전환의 첫 단계는 시스템 내 QV 암호 자산을 빠짐없이 식별하는 것이나, 소스코드 없는 수많은 레거시 바이너리가 혼재하는 대규모 환경에서 이는 막대한 자원을 요구하는 현실적 병목으로 작용한다.

선행 연구 QED [2]는 파일 수준 의존성 분석(P1), API 수준 의존성 분석(P2), angr 기반 정적 콜그래프 분석(P3)의 세 단계로 QV 실행파일을 탐지한다. 그러나 P3는 전체 실행 시간의 97.9%를 차지하고 최대 5GB 이상의 RAM을 소모하여 대규모 전수 스크리닝에 부적합하며, 함수 포인터를 통한 간접 호출을 추적하지 못

해 일부 QV 실행파일을 미탐하는 구조적 한계도 존재한다.

본 논문에서는 이러한 한계를 고려하여 탐지 정밀도에 비해 높은 연산 오버헤드를 유발하는 분석 단계를 경량화하고, 암호 라이브러리 버전 정보 기반으로 PQC 지원 여부를 직접 판정하는 경량 근사 도구 QED-Lite¹⁾를 제안한다. 1차 스크리닝 도구의 관점에서 TPR 최대화를 우선하며, FP는 보안 분석가의 후속 검토로 처리한다. 본 논문의 기여는 다음과 같다. 첫째, angr 및 관련 의존성을 완전히 제거하고 pyelftools 기반 정적 ELF 파싱으로 구현한 경량 근사 파이프라인을 설계하였다. 둘째, 11개 주요 암호 라이브러리를 대상으로 네 등급으로 구조화한 PQC 위험 등급 데이터베이스를 신규 구축하였다. 셋째, Network TPR 100%를 달성

1) 본 연구의 소스코드는 다음 저장소에 공개되어 있다: <https://github.com/HGKim442/QED-Lite.git>

하며 QED 대비 최대 855배 빠른 실행 시간 (0.84초)과 228배 적은 RAM 사용량(22.9MB)을 달성하였다.

II. 배경

2.1 암호 라이브러리별 PQC 지원 현황

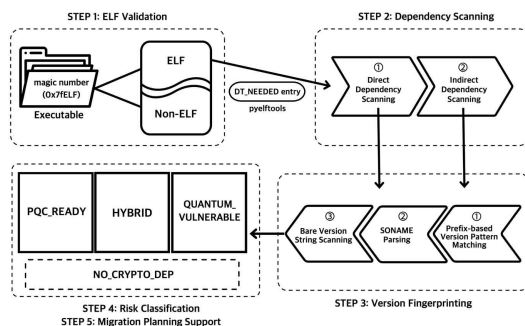
현재 Linux 환경에서 널리 사용되는 암호 라이브러리들은 NIST PQC 표준에 대한 수용 시점이 서로 상이하며, 이는 버전 단위의 세분화된 위험 판정이 필요함을 시사한다. OpenSSL은 3.5에서 ML-KEM, ML-DSA, SLH-DSA를 네이티브로 내장하였고 [3], wolfSSL은 5.8.0에서 NIST 표준을 완전히 반영하였다 [4]. 반면 mbedTLS는 최신 버전(4.0.0)에서도 NIST PQC 표준 알고리즘을 지원하지 않는다 [5]. 이처럼 동일 라이브러리라도 버전에 따라 위험 수준이 달라지므로 버전 단위의 세분화된 판정이 반드시 필요하다.

2.2 관련 연구

기존 바이너리 암호 탐지 연구들은 공통적으로 바이너리 내부에 어떤 암호 알고리즘이 구현되어 있는가를 식별하는 것을 목표로 하며, QV 라이브러리 버전 판정과는 목표가 다르다. 기존 PQC 전환 지원 도구들은 소스코드 접근이나 런타임 모니터링을 전제로 하여 블랙박스 바이너리 환경에 직접 적합하지 않다. 소스코드 없이 ELF 바이너리만으로 암호 라이브러리 버전 정보에 기반하여 대규모 환경에서 QV 실행 파일을 빠르게 1차 선별하는 도구는 드물며, 본 연구는 이 공백을 해결한다.

III. QED-Lite 설계

3.1 파이프라인 구조



QED-Lite의 분석은 다음 다섯 단계로 구성된다.

STEP 1에서 magic number(0x7fELF)로 비 ELF 파일을 조기 제외한다. STEP 2에서 pyelftools로 DT_NEEDED 엔트리를 추출하고 직접·간접(2홉) 의존성에서 암호 라이브러리를 탐색하며, 미탐지 시 NO_CRYPTODEP으로 조기 종료한다. STEP 3에서 .comment/.rodata 섹션 패턴 매칭 → soname 파싱 → .rodata 직접 탐색 순서로 버전을 추출하며, 실패 시 QUANTUM_VULNERABLE로 보수적 폴백을 적용한다. STEP 4에서 추출된 버전과 버전 DB를 대조하여 최종 등급을 결정하고, STEP 5에서 QUANTUM_VULNERABLE → HYBRID → PQC_READY의 단계적 업그레이드 경로를 자동 생성한다.

ldd를 pyelftools 기반 ELF 정적 파싱으로 교체하여 안전성·아키텍처 독립성을 확보하였으며, Python 3.8 이상 Linux 환경에서 단일 의존성(pyelftools)만으로 즉시 동작한다.

3.2 PQC 위험 등급 데이터베이스

QED-Lite는 11개 주요 암호 라이브러리 (OpenSSL, wolfSSL, mbedTLS, BoringSSL, LibreSSL, libsodium, Botan, GnuTLS, NSS, liboqs, libgcrypt)를 대상으로 공식 릴리즈 노트 기반의 PQC 지원 임계 버전을 정리한 version_db.py를 신규 구축하였다. 판정 기준은 NIST FIPS 203/204/205의 공식 표준 채택 여부이며, QUANTUM_VULNERABLE / HYBRID / PQC_READY / NO_CRYPTODEP의 네 등급으로 분류한다. 예를 들어 OpenSSL은 버전에 따라 세 등급에 걸쳐 분류되며, mbedTLS는 전 버전이 QUANTUM_VULNERABLE, BoringSSL은 전 버전이 PQC_READY로 분류된다. wolfSSL 등 컴파일 타임 옵션에 따라 PQC 지원 여부가 달라지는 라이브러리는 버전만으로 활성화 여부를 확인할 수 없어 HYBRID로 보수적 분류하였다.

IV. 실험 및 평가

4.1 실험 환경 및 데이터셋

데이터셋	속도 향상 QED→Lite	RAM 절감 QED→Lite	TPR: QED→Lite	TNR: QED→Lite
Synthetic	32x (17.33s→0.54s)	15x (324MB→21.3MB)	75% → 100%	100% → 0%
Network	855x (718s→0.84s)	228x (5,216MB→22.9MB)	85.7% → 100%	100% → 66.7%
tpm2-tools	326x (470s→1.44s)	162x (3,476MB→21.5MB)	—	—

[표 1] QED vs QED-Lite 성능 및 정확도 비교

실험은 Intel Core i7-10875H(8코어, 2.30GHz), 16GB RAM, Ubuntu 24.04(x86_64) 환경에서 수행하였으며, 실행 시간과 메모리 사용량은 `/usr/bin/time -v`로 3회 반복 측정한 평균값을 사용하였다. 데이터셋은 선행 연구 [2]와 동일하게 구성하였으며(합성 1종, 실세계 4종, 총 266개 ELF), 두 도구는 동일 하드웨어 및 데이터셋에서 측정하였으나 런타임 환경이 상이하므로(QED: Python 3.10 + angr 9.2.90, QED-Lite: Python 3.12.3 + pyelftools 0.32) 성능 차이의 핵심 원인은 분석 파이프라인 구조의 차이임을 4.2절에서 확인할 수 있다.

4.2 실험 결과

암호 라이브러리 의존성이 있는 Network, tpm2-tools 데이터셋에서 QED-Lite는 각각 855배, 326배의 속도 향상을 달성하였으며, P3가 전체 실행 시간의 97% 이상을 차지하는 것이 핵심 원인이다. 실행 기준 Network 데이터셋에서 P1은 1.016초, P2는 0.375초인 반면 P3는 703초로 전체의 97.9%를 차지한다. 정확도 측정은 Ground Truth가 확보된 Network 및 Synthetic 데이터셋을 대상으로 수행하였다. Network에서 QED가 FN으로 분류한 curl을 QED-Lite는 HYBRID 판정으로 탐지하였으며, QED P1과 동일한 보수적 성향(TPR 100%, TNR 66.7%)을 보였다. Synthetic에서는 TPR 100%이나 TNR 0%로, 암호 라이브러리에 링크된 모든 바이너리를 탐지하는 파일 수준 의존성 분석의 구조적 특성에 기인한다. tpm2-tools는 Ground Truth 판별이 불가능하여 정확도 비교에서 제외하였으나, 전량 QUANTUM_VULNERABLE로 분류되었다.

V. 결론

본 논문에서는 QED의 실용적 한계를 극복하기 위해 경량 근사 도구인 QED-Lite를 제안하였다. QED-Lite는 탐지 정밀도에 비해 높은 연

산 오버헤드를 유발하는 분석 단계를 경량화하고, 11개 주요 암호 라이브러리의 PQC 위험 등급 데이터베이스를 신규 구축하여 버전 정보 기반 판정을 수행한다. 실험 결과, Network 데이터셋 기준 TPR 100%를 유지하면서 QED 대비 최대 855배 빠른 실행 시간과 228배 적은 메모리 사용량을 달성하였다. QED-Lite는 대규모 조직 환경에서 현실적으로 운용 가능한 1차 스크리닝 도구로서 비용 대비 실용적인 선택을 제공한다. 향후 연구로는 정적 링킹 탐지 지원, 간접 의존성 탐색 깊이 확장, CI/CD 파이프라인 통합을 통한 지속적 PQC 전환 체계 구축을 계획한다.

VI. Acknowledgment

This work was supported by Institute of Information & communications Technology Planning & Evaluation (IITP) grant funded by the Korea government(MSIT) (No.RS-2025-02306395, Development and Demonstration of PQC-Based Joint Certificate PKI Technology, 40%) and this work was supported by the Institute of Information & Communications Technology Planning & Evaluation(IITP) grant funded by the Korea government(MSIT) (No. RS-2025-25394739, Development of Security Enhancement Technology for Industrial Control Systems Based on S/HBOM Supply Chain Protection, 40%) and this work was supported by the IITP(Institute of Information & Coummunications Technology Planning & Evaluation)-ITRC(Information Technology Research Center) grant funded by the Korea government(Ministry of Science and ICT)(IITP-2026-RS-2020-II201797, 20%)

[참고문헌]

- [1] National Institute of Standards and Technology, "NIST releases first 3 finalized post-quantum encryption standards," Aug. 2024. [Online]. Available: <https://www.nist.gov/news-events/news/2024/08/nist-releases-first-3-finalized-post-quantum-encryption-standards>
- [2] N. Rattanavipanon, J. Suaboot, W. Werapun, "A toolchain for assisting migration of software executables towards post-quantum cryptography," IEEE Access, vol. 13, pp. 4368 - 4380, 2025.
- [3] OpenSSL Library, "OpenSSL 3.5 final release," Apr. 2025. [Online]. Available: <https://openssl-library.org/post/2025-04-08-openssl-35-final-release/>
- [4] wolfSSL Inc., "wolfSSL 5.8.0 released," Apr. 2025. [Online]. Available: <https://www.wolfssl.com/wolfssl-5-8-0-released/>
- [5] Mbed TLS Contributors, "Release mbed tls 4.0.0," Oct. 2024. [Online]. Available: <https://github.com/Mbed-TLS/mbedtls/releases/tag/mbedtls-4.0.0>